

HOW TO PERFORM A CYBERSECURITY RISK ASSESSMENT

*A Practical Guide to Scope, Identify, Analyze, Treat, Document, and
Monitor Cyber Risk*

Alberto (Al) Leiva

Version 1.0 - July 2026

CC BY-NC-SA 4.0

Purpose and responsible-use notice

This manual teaches a repeatable, evidence-based method for assessing cybersecurity risk. It is designed for GRC analysts, security practitioners, managers, auditors, students, and career changers. It does not replace legal, regulatory, audit, insurance, or professional advice. Adapt the method to the organization, industry, jurisdiction, and risk appetite.

Human safety comes first. Risk decisions should protect people, essential services, privacy, accessibility, and organizational resilience. Do not conceal material risks or pressure assessors to produce a preferred rating.

How to use this manual

- Read Chapters 1-5 to understand the method.
- Use Chapters 6-12 as the working assessment procedure.
- Use Chapters 13-16 for reporting, treatment, monitoring, and career evidence.
- Copy the sample templates into a spreadsheet, GRC platform, ticketing system, or approved document repository.

Table of contents

- 1. Risk assessment fundamentals
- 2. Roles, governance, and independence
- 3. Define scope and context
- 4. Identify assets, services, and data
- 5. Identify threats and threat events
- 6. Identify vulnerabilities and control gaps
- 7. Analyze likelihood
- 8. Analyze impact
- 9. Calculate and communicate risk
- 10. Evaluate controls and residual risk
- 11. Develop treatment plans
- 12. Document the risk register
- 13. Report to leaders and stakeholders
- 14. Monitor and reassess
- 15. Common mistakes and quality checks
- 16. Portfolio project and 30/60/90-day plan
- 17. Templates and examples
- 18. Glossary and official references

1. Risk assessment fundamentals

A cybersecurity risk assessment is a structured process for understanding what can go wrong, why it could happen, how serious the consequences could be, and what should be done. NIST SP 800-30 describes risk assessment as part of a broader risk management process. NIST CSF 2.0 places risk strategy, roles, policy, oversight, and supply-chain risk within GOVERN and risk identification within IDENTIFY.

Term	Practical meaning
Asset	A system, service, process, person, facility, dataset, supplier, or capability that has value.
Threat	A circumstance or actor with the potential to cause harm.
Threat event	A specific event such as credential theft, ransomware execution, cloud misconfiguration, or supplier outage.
Vulnerability	A weakness that could be exploited or contribute to harm.
Control	A safeguard that changes likelihood, impact, or both.
Inherent risk	Risk before considering current controls.
Residual risk	Risk remaining after considering current controls.
Risk appetite	The broad amount and type of risk an organization is willing to pursue or retain.
Risk tolerance	Specific acceptable variation around objectives or thresholds.

A simple risk statement

Because [threat event] may exploit [vulnerability or condition] affecting [asset or process], the organization could experience [business impact].

Example: Because a threat actor may use stolen administrator credentials against an internet-accessible remote access service without phishing-resistant MFA, the organization could experience unauthorized network access, ransomware deployment, operational disruption, and data disclosure.

2. Roles, governance, and independence

Role	Responsibilities
Executive sponsor	Approves scope, resolves barriers, and accepts or escalates significant risk.
Risk owner	Owns the business objective and decides treatment within delegated authority.
Assessment lead	Plans the assessment, applies the method consistently, and maintains evidence.

System or service owner	Explains architecture, dependencies, users, changes, and current controls.
Control owner	Operates a safeguard and provides evidence of design and performance.
Security and privacy specialists	Provide technical, legal, privacy, safety, and compliance analysis.
Internal audit or independent reviewer	Challenges assumptions and evaluates quality or assurance.
Third party	Provides accurate information about services, controls, incidents, and dependencies.

- Document conflicts of interest.
- Do not allow the control owner to be the only reviewer of control effectiveness.
- Record disagreements and the decision authority.
- Protect interview notes, architecture, vulnerabilities, and risk records according to classification.

3. Define scope and context

A clear scope prevents an assessment from becoming either superficial or endless. Define the business objective first, then the technology and dependencies that support it.

Scope element	Questions
Business purpose	What mission, customer, legal, safety, or revenue objective does the service support?
Boundary	Which applications, identities, networks, locations, cloud subscriptions, APIs, and endpoints are included?
Data	What data is collected, processed, transmitted, stored, logged, or deleted?
People	Who administers, uses, supports, approves, or is affected by the service?
Suppliers	Which vendors, processors, open-source components, and utilities are dependencies?
Time horizon	Are we assessing current state, a proposed change, an acquisition, or a multi-year strategy?
Criteria	Which likelihood, impact, risk, and acceptance scales will be used?
Constraints	What evidence, time, access, budget, or expertise limitations exist?

Minimum scope statement

This assessment covers [service and business process], including [systems, data, identities, environments, and suppliers], for the period [date range]. It evaluates [risk types] using [method and scales]. It excludes [items], which will be addressed by [owner/date or separate assessment].

4. Identify assets, services, and data

- Start from critical business services rather than only a device list.
- Map systems, applications, identities, data stores, networks, facilities, and suppliers.
- Identify crown-jewel assets and single points of failure.
- Record data classification, residency, retention, and backup requirements.
- Document upstream and downstream dependencies.
- Validate the inventory with technical evidence such as cloud inventories, CMDB records, identity directories, network diagrams, and contracts.

Asset record field	Example
Business service	Online customer payment service
Owner	Digital Commerce Director
Criticality	High
Data	Payment and customer contact data
RTO/RPO	4 hours / 30 minutes
Dependencies	Identity provider, cloud platform, payment processor, DNS
Exposure	Internet-facing
Evidence	Architecture diagram, CMDB export, data flow, contract

5. Identify threats and threat events

Use more than a generic threat list. Connect credible actors and conditions to specific events that could affect the scoped objective.

Threat source	Example threat events
External criminal	Phishing, ransomware, credential stuffing, extortion, payment fraud.
Nation-state or advanced actor	Espionage, supply-chain compromise, destructive operations.
Insider	Intentional theft, sabotage, unauthorized disclosure, policy bypass.
Accidental human action	Misconfiguration, mistaken deletion, wrong recipient, insecure sharing.
Supplier or partner	Service outage, compromised update, weak access, breach notification delay.
Technology failure	Storage corruption, certificate expiration, software defect, capacity failure.

Environmental or physical	Power loss, fire, flood, theft, cooling failure.
Governance failure	Unclear ownership, unapproved AI use, missing retention, unmanaged exceptions.

- Use internal incidents, near misses, vulnerability findings, fraud reports, help-desk trends, and audit observations.
- Use trusted external threat intelligence and sector alerts.
- Distinguish possibility from credibility. A scenario should be plausible for the organization and scope.
- Avoid assuming that a threat is irrelevant only because it has not happened before.

6. Identify vulnerabilities and control gaps

A vulnerability may be technical, procedural, contractual, organizational, physical, or human. A missing control is not automatically a vulnerability; explain how the condition enables or worsens a threat event.

Evidence source	What it may reveal
Configuration review	Public exposure, weak authentication, excessive permissions, insecure defaults.
Vulnerability scan	Known software flaws and missing patches.
Penetration test	Exploitable paths and chained weaknesses within authorized scope.
Control interview	Unclear ownership, manual workarounds, inconsistent operation.
Sample testing	Failed approvals, incomplete reviews, missing records.
Incident history	Controls that failed under real conditions.
Contracts and reports	Supplier limitations, exclusions, weak notification or recovery commitments.
Architecture review	Trust-boundary, segmentation, concentration, and single-point-of-failure issues.

Evidence quality

- Prefer current, direct, reproducible evidence.
- Record the evidence date, source, owner, and limitations.
- Do not treat a policy document as proof that a control operates.
- Do not treat one successful sample as proof of consistent operation.
- When evidence is missing, record uncertainty rather than assuming effectiveness.

7. Analyze likelihood

Likelihood is an informed judgment about the chance that a threat event will occur and produce harm during the stated time horizon. Use defined criteria and evidence, not intuition alone.

Rating	Example criterion
1 - Rare	Not expected in the period; strong barriers; no credible history or active targeting.
2 - Unlikely	Possible but requires unusual conditions or multiple failures.
3 - Possible	Credible and could occur; similar events exist in the organization or sector.
4 - Likely	Expected in many circumstances; active exposure, recurring attempts, or weak barriers.
5 - Almost certain	Expected repeatedly or already occurring; highly exposed and easily exploited.

- Consider threat capability, intent, targeting, frequency, exposure, ease of exploitation, and control reliability.
- Separate event likelihood from impact. A likely event can have low impact, and a rare event can be catastrophic.
- State the time horizon, such as the next 12 months.
- Document uncertainty and use ranges or scenarios when evidence is weak.

8. Analyze impact

Impact should describe consequences to business objectives and people, not only technical severity.

Impact area	Questions
Safety and human impact	Could people be physically harmed, denied essential services, discriminated against, or exposed to severe distress?
Operations	How long could the service be unavailable or degraded? What manual alternatives exist?
Confidentiality and privacy	What data could be exposed, to whom, and at what scale?
Integrity	Could records, decisions, models, configurations, or financial data be altered?
Financial	What response, recovery, fraud, lost revenue, penalties, or contractual costs may occur?
Legal and regulatory	What notification, investigation, litigation, or licensing consequences apply?
Reputation and trust	Would customers, employees, partners, or the public lose confidence?

Strategic	Could the event prevent objectives, acquisition, market entry, or critical transformation?
-----------	--

Rating	Example criterion
1 - Insignificant	Minimal interruption; no material data, legal, safety, or financial consequence.
2 - Minor	Limited local impact; routine recovery; small cost or short interruption.
3 - Moderate	Material business disruption, reportable issue, or meaningful customer impact.
4 - Major	Severe disruption, significant data exposure, regulatory action, or major financial loss.
5 - Catastrophic	Threat to life or essential services, enterprise-wide failure, or existential legal/financial harm.

9. Calculate and communicate risk

A matrix can support consistency, but multiplication does not create scientific precision. The narrative, evidence, uncertainty, and business context are more important than the arithmetic.

Likelihood x Impact	Suggested level
1-4	Low
5-9	Moderate
10-16	High
17-25	Critical

Example 5 x 5 matrix

Impact → / Likelihood ↓	1	2	3	4	5
5 - Almost certain	5 M	10 H	15 H	20 C	25 C
4 - Likely	4 L	8 M	12 H	16 H	20 C
3 - Possible	3 L	6 M	9 M	12 H	15 H
2 - Unlikely	2 L	4 L	6 M	8 M	10 H
1 - Rare	1 L	2 L	3 L	4 L	5 M

- Define ratings before the assessment begins.
- Allow documented professional judgment when the matrix result does not reflect the real business consequence.
- Do not average unrelated risks into one score.
- Use clear risk statements and explain the evidence behind each rating.

10. Evaluate controls and residual risk

Evaluate both control design and operating effectiveness. A well-written control that is not performed does not reduce risk.

Dimension	Questions
Design	Would the control, if performed as designed, reduce the stated scenario?
Implementation	Is it deployed across the full intended scope?
Operation	Is it performed consistently and at the required frequency?
Coverage	Does it protect all relevant identities, systems, locations, and suppliers?
Reliability	Is it automated, monitored, tested, and resistant to bypass?
Evidence	Can operation be demonstrated with reliable records?
Dependencies	Does the control rely on another control that may fail?

Effectiveness	Description
Effective	Appropriately designed, implemented, operating, and evidenced.
Partially effective	Reduces risk but has coverage, consistency, or evidence gaps.
Ineffective	Does not reliably reduce the scenario.
Not implemented	Planned or required but absent.
Not assessed	Insufficient evidence; uncertainty must be recorded.

Reassess likelihood and impact after considering effective controls. Record residual risk and compare it with risk appetite, tolerance, and delegated acceptance authority.

11. Develop treatment plans

Option	Use
Mitigate	Add or improve controls to reduce likelihood or impact.
Avoid	Stop the activity, remove exposure, or choose a different design.
Transfer or share	Use insurance, contract terms, outsourcing, or shared responsibility, while recognizing that accountability may remain.
Accept	Formally retain the risk within authority and tolerance, with rationale and review date.

SMART treatment actions

- Specific: identify the exact control or change.
- Measurable: define evidence and success criteria.
- Assigned: name one accountable owner.
- Realistic: confirm resources, dependencies, and approvals.
- Time-bound: set milestones and a final due date.

Weak action	Improved action
Improve access control	By 30 September, migrate all privileged remote access to phishing-resistant MFA, remove shared administrator accounts, and provide Entra sign-in and access-review evidence.
Patch servers	Within 30 days, remediate critical internet-facing vulnerabilities; report weekly exceptions with compensating controls and approved deadlines.
Train users	Deliver role-based phishing and reporting training to 95% of users, test reporting behavior, and repeat training for high-risk groups.

12. Document the risk register

Field	Purpose
Risk ID and title	Unique reference and concise name.
Business objective and asset	What is at risk and why it matters.
Risk statement	Threat, condition, asset, and consequence.
Scope and assumptions	Boundary, time horizon, exclusions, and uncertainty.
Existing controls	Safeguards relevant to the scenario.
Evidence	Documents, records, tests, interviews, and dates.
Inherent likelihood and impact	Pre-control ratings.
Control effectiveness	Design and operation conclusion.
Residual likelihood and impact	Post-control ratings.
Risk owner	Person accountable for the business decision.
Treatment and owner	Actions, milestones, evidence, and due date.
Acceptance authority	Person authorized to accept the residual risk.
Status and review date	Lifecycle tracking and reassessment trigger.

Worked example

Field	Example
Title	Privileged remote access compromise
Risk statement	A threat actor may use stolen credentials

	against internet-facing remote access without phishing-resistant MFA, causing unauthorized access, ransomware, disruption, and data exposure.
Inherent risk	Likelihood 4; Impact 5; Critical 20
Existing controls	Password MFA for most users, VPN logging, endpoint protection.
Control assessment	Partially effective; legacy accounts and shared administration remain.
Residual risk	Likelihood 3; Impact 5; High 15
Treatment	Deploy phishing-resistant MFA, remove shared accounts, restrict source locations, create privileged access workstations, test recovery.
Owner and due date	Infrastructure Director; 30 September 2026
Review trigger	Material architecture change, related incident, or due date.

13. Report to leaders and stakeholders

- Lead with business objectives and decisions required.
- Show top risks, trends, overdue actions, accepted risks, and concentration risk.
- Separate facts, assumptions, and professional judgment.
- Explain uncertainty and evidence limitations.
- Avoid overwhelming executives with raw vulnerability counts.
- Tailor technical detail to system owners and implementation teams.
- Preserve a record of decisions and approvals.

One-page executive summary

- Scope and assessment date
- Overall conclusion
- Top three to five scenarios
- Business impact
- Existing strengths
- Priority actions and required investment
- Risks requiring acceptance or escalation
- Key assumptions and limitations
- Next review date

14. Monitor and reassess

Risk is not static. Reassess after meaningful change and at a frequency appropriate to criticality.

- New system, cloud, AI, supplier, merger, or acquisition
- Material architecture or data-flow change

- Major vulnerability or threat campaign
- Security incident or near miss
- Control failure or overdue treatment
- Regulatory or contractual change
- Business criticality change
- Periodic review date

Indicator	Example
Key risk indicator	Percentage of privileged accounts without phishing-resistant MFA.
Control indicator	Percentage of critical systems sending logs to the SIEM.
Treatment indicator	High risks past due by owner and business unit.
Exposure indicator	Internet-facing critical vulnerabilities older than 15 days.
Resilience indicator	Percentage of critical services with tested recovery objectives.

15. Common mistakes and quality checks

Mistake	Better practice
Starting with a generic checklist	Start with the business service, objective, and data flow.
Calling every finding high risk	Use defined criteria and scenario-specific impact.
Equating compliance with security	Assess actual threats, controls, and business consequences.
Counting policies as operating controls	Test implementation and evidence.
Ignoring suppliers and concentration	Map dependencies and common failure points.
Hiding uncertainty	Record missing evidence, assumptions, and confidence.
Accepting risk without authority	Use documented delegated acceptance thresholds.
Leaving treatment vague	Define owner, action, evidence, milestone, and due date.
Never closing the loop	Retest treatment and update residual risk.

Quality review checklist

- ☐ Scope is explicit and approved
- ☐ Risk statements connect threat, condition, asset, and consequence
- ☐ Ratings use defined criteria

- ☐ Evidence is current and traceable
- ☐ Inherent and residual risk are not confused
- ☐ Control effectiveness is supported
- ☐ Treatment actions are specific and assigned
- ☐ Acceptance uses the correct authority
- ☐ Limitations and uncertainty are visible
- ☐ Review triggers and dates are recorded

16. Portfolio project and 30/60/90-day plan

Safe portfolio project

- Choose a fictional small business or an authorized lab.
- Create a scope statement and simple architecture diagram.
- Inventory five to ten assets and data types.
- Write five credible risk scenarios.
- Define likelihood and impact scales.
- Assess existing controls and residual risk.
- Create a risk register and one-page executive summary.
- Publish only fictional, sanitized information; never expose real vulnerabilities, credentials, customer data, or confidential architecture.

First 30 days

- Study risk vocabulary, NIST CSF 2.0, and NIST SP 800-30.
- Practice writing risk statements.
- Build likelihood and impact criteria.
- Create a sample asset inventory and risk register.

Days 31-60

- Perform an assessment of a fictional or authorized service.
- Practice control interviews and evidence evaluation.
- Write treatment plans and an executive summary.
- Ask a mentor to challenge assumptions and ratings.

Days 61-90

- Map risks to relevant controls and business objectives.
- Create metrics and reassessment triggers.
- Publish a sanitized GitHub portfolio project with README and templates.
- Practice explaining one risk to a technical owner and an executive.

17. Templates and examples

Risk interview questions

- What business outcome does this service support?
- What would happen if it were unavailable for one hour, one day, or one week?
- What sensitive data does it process?
- Who has privileged access and how is it reviewed?
- Which suppliers and integrations are essential?
- What security events or near misses have occurred?
- Which controls are manual, inconsistent, or difficult to evidence?
- What upcoming changes could alter risk?
- Which risk decisions need executive approval?

Treatment tracking template

Risk ID	Action	Owner	Milestone	Due date	Evidence	Status
R-001	Deploy phishing-resistant MFA	IAM Manager	Pilot complete	2026-09-30	Configuration + sign-in logs	Open
R-002	Test offline recovery	Infrastructure Manager	Restore exercise	2026-10-15	Exercise report	Planned

18. Glossary and official references

Term	Definition
Risk	Effect of uncertainty on objectives; in cybersecurity, commonly expressed through likelihood and impact.
Risk scenario	A structured description of how a threat event could create consequences.
Inherent risk	Risk before current controls.
Residual risk	Risk after considering current controls.
Control design	Whether a control is capable of reducing the stated risk.
Operating effectiveness	Whether the control works consistently in practice.
Risk owner	Person accountable for managing and deciding about a risk.
Risk acceptance	Authorized decision to retain residual risk.
KRI	Key risk indicator used to monitor changing exposure.
Reassessment trigger	Event or date requiring the risk to be reviewed again.

[NIST SP 800-30 Rev. 1 - Guide for Conducting Risk Assessments](#)

[NIST Cybersecurity Framework 2.0](#)

[NIST Risk Management Framework](#)

[CISA Risk Assessments](#)

Copyright © 2026 Alberto (Al) Leiva. Licensed under CC BY-NC-SA 4.0.